PLAYBOOK DE RESPUESTA

PB-05 | Uso de USB no autorizado

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva

Control documental	Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.
Activo / ámbito	8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Impedir salida de información financiera tokenizada, identificadores y claves desde estaciones corporativas.

02. Disparador, fuente y umbral

Kaspersky Device Control en estaciones Windows/macOS compatibles. Umbral propuesto: conexión no autorizada siempre genera revisión; transferencia de datos sensibles eleva a Alta.

03. Severidad inicial y promoción

Baja si fue bloqueado sin copia; Media si se copió información; Alta si involucra llaves, informes financieros o reincidencia.

04. Triage: validación paso a paso

1. Distinguir dispositivo detectado, bloqueado o permitido.
2. Cotejar host, usuario y tipo/identificador de USB con inventario aprobado.
3. Revisar trazas de copia y volumen cuando existan; no asumir que hubo copia sólo por conexión.
4. Solicitar confirmación de propósito al usuario y autorización de TI.
5. Correlacionar detecciones antimalware en dispositivo y endpoint.

05. Contención autorizada a N1

- Solicitar retiro del dispositivo y mantener política de bloqueo.
- Notificar al responsable SOC ante exposición potencial de datos.

06. Acciones no autorizadas a N1

- No montar ni abrir el medio desconocido para inspección manual.
- No modificar controles ni excepciones de dispositivos.

07. Evidencia mínima preservada

- Evento de Device Control, host/usuario, identificador del medio, fecha y estado.
- Evidencia de copia sólo si el sistema realmente la registra.

08. Escalamiento obligatorio a N2

Copia de datos financieros, malware en USB o reincidencia de usuario con acceso sensible.

09. Criterios de cierre técnico

Dispositivo bloqueado y sin acceso a datos; educación y trámite formal de excepciones.

10. Mejora continua

Lista blanca de dispositivos con vencimiento y alertas DLP.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-05 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no detecciones que se haya comprobado activar.